

Clase 278 — ISO/IEC 27001 e implantación de un SGSI

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: *ISO/IEC 27001:2022 e ISO/IEC 27002:2022* 🕒
Duración estimada: **120 min** · Nivel: **Intermedio**

Objetivo

Entender qué es un Sistema de Gestión de Seguridad de la Información (SGSI) y cómo se implanta según ISO/IEC 27001:2022, la norma internacional certificable más extendida. Al terminar sabrás recorrer el ciclo PDCA, elaborar una Declaración de Aplicabilidad (SoA), gestionar el riesgo conforme a la norma y preparar una organización para auditoría de certificación.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

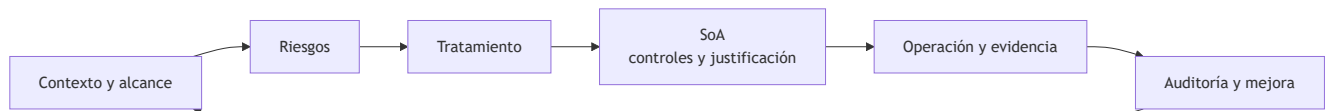
- 1. **Describir** la estructura de ISO/IEC 27001:2022 (cláusulas 4–10 y Anexo A).
- 2. **Definir** el alcance de un SGSI y su contexto.
- 3. **Ejecutar** el proceso de gestión de riesgo exigido por la norma.
- 4. **Elaborar** una Declaración de Aplicabilidad (SoA) justificando inclusiones y exclusiones.
- 5. **Preparar** la evidencia y auditoría interna previa a la certificación.

Temas

#	Tema	Por qué importa
1	Familia ISO 27000	Ubica 27001, 27002, 27005, 27701
2	Cláusulas 4–10 (requisitos)	Lo que se audita para certificar
3	Ciclo PDCA	Mejora continua del SGSI
4	Anexo A (93 controles, 4 temas)	Catálogo de controles v2022
5	Declaración de Aplicabilidad (SoA)	Documento central de la certificación
6	Auditoría de certificación (etapas 1 y 2)	Cómo se obtiene el sello
7	No conformidades y acciones correctivas	Mantener la certificación

Explicación en profundidad

ISO/IEC 27001 especifica requisitos para un sistema de gestión, no una lista universal de controles técnicos. La organización define contexto, partes interesadas, alcance y criterios; evalúa riesgos; selecciona tratamiento; compara con Anexo A y explica inclusión o exclusión en la Declaración de Aplicabilidad. La certificación evalúa conformidad del SGSI dentro de un alcance, no ausencia de incidentes.



Caso razonado

Una empresa copia 93 controles y declara todos aplicables. No puede explicar qué riesgo trata cada uno. Rehace el alcance, enlaza controles con tratamiento y conserva responsables y evidencia; el SGSI se vuelve un mecanismo de decisión.



Glosario operativo

Término	Definición
SGSI	Sistema de gestión para dirigir y mejorar seguridad de información.
SoA	Declaración que justifica controles aplicables y su estado.
Alcance	Frontera organizativa, tecnológica y física del SGSI.



Criterio de dominio

El alumno puede construir la cadena contexto–riesgo–tratamiento–SoA–evidencia y explicar los límites de certificación.



Definiciones y características

- **SGSI:** sistema de gestión que establece, implementa, mantiene y mejora la seguridad de la información. *Clave:* es un sistema de gestión, no un producto.
- **ISO/IEC 27001:** norma certificable con los requisitos del SGSI (cláusulas 4–10). *Clave:* lo obligatorio se expresa con "debe".
- **ISO/IEC 27002:** guía de implementación de los controles del Anexo A. *Clave:* no es certificable, es orientativa.
- **Anexo A (2022):** 93 controles agrupados en 4 temas (Organizacional, Personas, Físico, Tecnológico). *Clave:* reemplazó los 114 controles/14 dominios de 2013.
- **SoA (Statement of Applicability):** documento que lista qué controles aplican, cuáles no y por qué. *Clave:* pieza obligatoria y auditada.
- **PDCA:** Plan-Do-Check-Act, el motor de mejora continua. *Clave:* la certificación exige evidencia de las 4 fases.
- **No conformidad:** incumplimiento de un requisito; mayor o menor. *Clave:* una mayor bloquea la certificación hasta corregirla.



Herramientas y preparación

- Editor de documentos y hoja de cálculo para el SoA y el registro de riesgos.
- El índice de ISO/IEC 27001:2022 (puedes consultar la estructura pública; el texto íntegro es de pago en iso.org).
- Referencia de controles: *ISO/IEC 27002:2022* para descripciones.

- Opcional: plantillas abiertas de SoA (busca "ISO 27001 SoA template") como referencia estructural, sin copiar contenido.
- Herramientas GRC opcionales para gestionar evidencia: Eramba (open source), o simples carpetas versionadas.

Laboratorio guiado (ejercicio aplicado)

Vas a preparar los documentos núcleo del SGSI de "Ferretería del Sur S.A.".

1. **Alcance:** redacta en un párrafo el alcance del SGSI (p. ej. "la plataforma de e-commerce, su infraestructura cloud y el proceso de pagos"). Indica qué queda fuera.
2. **Contexto y partes interesadas** (cláusula 4): lista 5 partes interesadas (clientes, banco adquirente, reguladores, empleados, proveedores cloud) y sus expectativas de seguridad.
3. **Liderazgo** (cláusula 5): redacta el compromiso de dirección en 3 frases y asigna el propietario del SGSI.
4. **Registro de riesgos** (cláusula 6): reutiliza los 3 riesgos de la clase 277 en una hoja con: activo, amenaza, probabilidad, impacto, nivel y tratamiento.
5. **Selección de controles:** para cada riesgo, elige controles del Anexo A (p. ej. A.5.7 Inteligencia de amenazas, A.8.7 Protección contra malware, A.8.13 Copias de seguridad).
6. **Declaración de Aplicabilidad:** crea una hoja con las columnas: control, aplica (Sí/No), justificación, estado de implementación. Rellena al menos 15 controles, incluyendo alguna exclusión justificada (p. ej. A.7.x físico si todo es cloud).
7. **Auditoría interna** (cláusula 9): escribe 5 preguntas que un auditor haría y anota qué evidencia presentarías.
8. **Cierre PDCA:** identifica una acción de mejora (Act) derivada de un hallazgo.

Ejercicios

1. Explica la diferencia entre ISO 27001 e ISO 27002.
2. ¿Por qué el SoA es obligatorio y qué pasa si excluyes un control sin justificarlo?
3. Mapea estos riesgos a controles del Anexo A: phishing, pérdida de laptop, acceso no revocado a un ex-empleado.
4. Redacta una política de seguridad de la información conforme a la cláusula 5.2 (máx. 15 líneas).
5. Distingue una no conformidad mayor de una menor con un ejemplo de cada.
6. Describe qué se revisa en la etapa 1 vs. la etapa 2 de la auditoría de certificación.

Reto verificable

Entrega una **Declaración de Aplicabilidad (SoA)** con al menos 20 controles del Anexo A:2022, cada uno marcado como aplicable/no aplicable, con justificación y estado, acompañada del registro de riesgos que la sustenta.

Criterio de aceptación: cada control incluye justificación (no solo "Sí/No"), hay al menos una exclusión razonada, y cada control aplicable está trazado a un riesgo del registro.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
SoA con controles marcados sin justificar	El auditor lo rechaza; añade justificación por control
Alcance demasiado amplio o vago	Certificación inviable; delimita alcance concreto y realista
Confundir certificar la empresa con certificar un producto	Se certifica el SGSI dentro de un alcance, no un producto
Riesgos sin dueño ni tratamiento	Incumple cláusula 6; asigna propietario y decisión
Documentar todo pero no operarlo	El auditor busca evidencia de ejecución, no solo papeles

Preguntas frecuentes

 **¿Cuánto se tarda en certificar?** Típicamente 6–12 meses para una PYME, según madurez previa. La auditoría tiene etapa 1 (documental) y etapa 2 (implementación).

 **¿27001:2022 obliga a los 93 controles?** No. Aplicas los que tu análisis de riesgo justifique; el resto se excluye con motivo en el SoA.

 **¿ISO 27001 cubre GDPR?** Ayuda, pero no basta. Para privacidad se complementa con *ISO/IEC 27701* y con el propio GDPR (clase 281 y 289).

 **¿Cada cuánto se re-audita?** La certificación dura 3 años con auditorías de seguimiento anuales, más una recertificación al final del ciclo.

Referencias

- ISO/IEC 27001:2022. <https://www.iso.org/standard/27001>
- ISO/IEC 27002:2022 — Controles de seguridad de la información. <https://www.iso.org/standard/75652.html>
- ISO/IEC 27005:2022 — Gestión de riesgos. <https://www.iso.org/standard/80585.html>
- ISO/IEC 27701 — Extensión de privacidad (PIMS). <https://www.iso.org/standard/71670.html>
- (ISC)² CISSP Official Study Guide, dominio 1.

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 277 — Gestión de riesgos: cuantitativa y cualitativa](#)

Siguiente clase

Clase 279 — NIST Cybersecurity Framework